KRIPTOGRAFI

MINGGU 1

Apa Artinya Sistem "Aman"?

Kita tidak belajar algoritma hari ini.
Kita belajar cara berpikir.

Security Mindset over Algorithm



01001011
01110010
01101001

Mengapa Kita Di Sini?

Semua sistem digital menyimpan rahasia:



Identitas

- Username & Password
- NIK / KTP



Finansial

- Saldo e-wallet
- Nomor Kartu Kredit



Privasi

- Chat WhatsApp
- Riwayat Browsing

Pertanyaan Pemantik: "Apa sebenarnya yang kita lindungi?"

🔥 Studi Kasus 1: Pemanasan

Analisis keamanan sederhana

Website menyimpan password user ke database dengan metode:

password (plaintext) → **Base64** (encoding) → **database** (storage)

id	username	password_stored
1	alice	dXNlcjEyMw==
2	bob	cGFzc3dvcmQ=
3	charlie	YWJjMTIzIQ==

⚠️ Masalah!

Base64 bukan enkripsi.
Siapapun bisa decode
nya secara instan!

echo dXNlcjEyMw== | base64 -d
→ user123

Aman atau tidak?. Diskusikan dulu sebelum menjawab!

⚡ Plot Twist!

Metode diganti ke standar industri:

`password` → **AES** → `database`

Apakah sekarang otomatis aman?



Jika jawabanmu otomatis **"IYA"**,
berarti kamu belum paham keamanan.

Di mana kunci AES-nya disimpan?

Siapa yang bisa mengakses kunci itu?

Apakah kunci ikut bocor jika server di-hack?

💡 Masalah Mindset

Cara berpikir yang benar tentang keamanan

❌ SALAH



Keamanan = **Pakai algoritma paling keren / rumit**

✅ BENAR



Keamanan = **Memenuhi tujuan (property) yang spesifik**

Analogi: Memakai baju zirah besi lengkap, tapi lupa membawa senjata! Kuat di satu sisi, celah di sisi lain.

4 Pilar Kriptografi

"Kriptografi tidak membuat sistem aman. Kriptografi memenuhi Properti Keamanan."

1



Confidentiality

Kerahasiaan Data

2



Integrity

Keutuhan Data

3



Authentication

Keaslian Identitas

4



Non-Repudiation

Anti-Sangkalan

1. Confidentiality

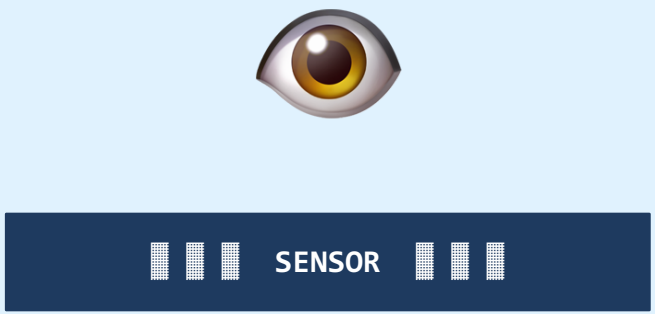
Kerahasiaan. Data tidak bisa dibaca pihak yang tidak berwenang

Definisi

Data tidak bisa dibaca oleh pihak ketiga yang tidak berwenang, bahkan jika berhasil dicegat di tengah perjalanan.

Analogi

Surat dalam amplop tertutup, tukang pos mengantarkan, namun tidak bisa membaca isinya.



Pihak ketiga mencoba mengintip, tapi tidak bisa membaca!

Diskusi: Apakah password di database perlu Confidentiality? Apakah enkripsi cukup untuk menjaminnya?

2. Integrity

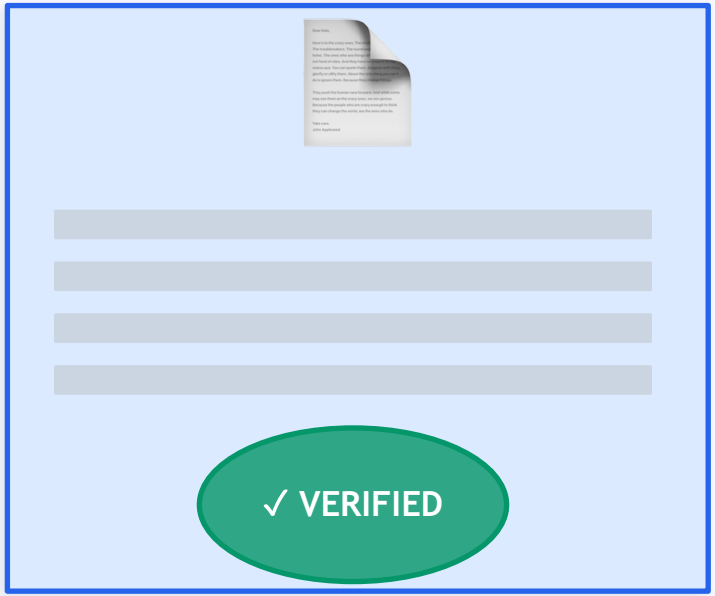
Integritas. Data tidak berubah tanpa diketahui pemiliknya

Definisi

Data tidak berubah tanpa sepengetahuan pemiliknya atau sistem yang berwenang, baik sengaja maupun tidak.

Bocor ≠ Berubah
Berubah ≠ Bocor

Contoh nyata: Nilai ujian diubah dari C menjadi A tanpa mencuri data apapun. Ini pelanggaran INTEGRITY, bukan Confidentiality!



Kunci:
Integrity melindungi dari modifikasi diam-diam. Enkripsi saja tidak cukup, butuh MAC atau Digital Signature.

3. Authentication

Autentikasi. Memverifikasi bahwa identitas pihak lain adalah benar

Definisi

Proses memverifikasi bahwa identitas pihak lain adalah benar dan sah, bukan seseorang yang hanya berpura-pura.

Masalah di Internet

Kamu tidak tahu siapa yang ada di balik layar.
Siapa saja bisa berpura-pura menjadi bankmu, bosmu, temanmu.

Tanpa Authentication:
Phishing, man-in-the-middle, dan impersonation menjadi mudah.



"On the internet,
nobody knows you're a dog."

Solusi: Protocol autentikasi, sertifikat digital, dan password yang di-hash secara benar.

4. Non-Repudiation

Anti-Sangkalan. Pengirim tidak dapat menyangkal aksinya

Definisi

Pengirim tidak dapat menyangkal (mengelak) bahwa mereka telah mengirimkan pesan atau melakukan tindakan tertentu.

Contoh Nyata

- Kontrak digital yang sudah ditandatangani
- Transaksi transfer uang via m-banking
- Email resmi perusahaan



Digital Signature
(Tanda Tangan Digital)

Saya tidak pernah mengirim itu!" Digital Signature membuktikan sebaliknya. Tidak bisa disangkal.

⚡ Latihan Cepat — Diskusi!

Tentukan Properti Utama yang Dibutuhkan:

Sistem / Kasus	Properti Paling Kritis	Alasan Singkat
💬 Grup Chat Kelas	**Confidentiality**	Chat tidak boleh dibaca orang luar
📱 Update Software HP	**Integrity**	Pastikan file tidak dimodifikasi hacker
🏦 Login e-Banking	**Authentication**	Pastikan pengguna adalah benar-benar pemilik akun
📝 Tanda Tangan Digital	**Non-Repudiation**	Pengirim kontrak tidak bisa menyangkal

Satu sistem bisa membutuhkan lebih dari satu properti! Manakah yang paling kritis?

🕵️ Mengenal "Si Musuh”/Attacker Model

Keamanan bersifat relatif terhadap jenis penyerang.



Passive

Hanya Mengintip

Membaca / menyadap traffic.
Tidak mengubah apapun.

Read Only



Active

Modifikasi / Menyamar

Mengubah data atau berpura-pura menjadi pihak lain.

Modify / Impersonate



Insider

Orang Dalam

Punya akses resmi.
Paling sulit dideteksi.

Internal Threat

Desain sistem = merancang pertahanan yang spesifik untuk jenis penyerang yang mungkin datang.

🚫 Keamanan Absolut Itu Mitos

Tidak ada sistem yang 100% aman, dan itu bukan kegagalan.

Sistem aman = **Aman terhadap penyerang tertentu** + dalam **asumsi tertentu**



Prinsip Ekonomi Keamanan

Jika biaya membobol > nilai data, sistem dianggap "aman secara praktis".



Analogi Brankas

Brankas di padang pasir terbuka — kuat, tapi lingkungan tidak dilindungi.



Security = Trade-off

Selalu ada pertukaran antara keamanan, kemudahan, dan biaya.

"If the cost to break > value of the data, the system is considered secure." Prinsip dasar kriptografi modern

🔧 Matriks Masalah & Solusi

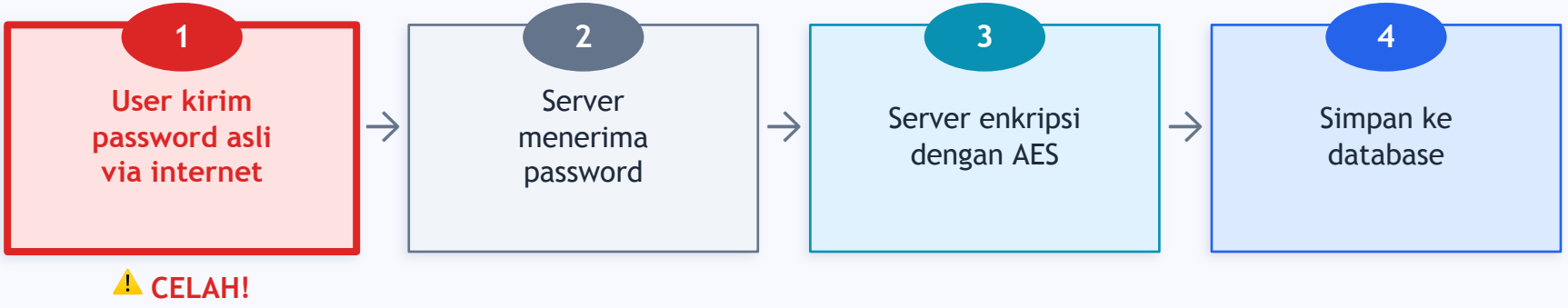
Tidak semua alat cocok untuk semua masalah:

Masalah Keamanan	❌ BUKAN Solusi	✅ Solusi yang Tepat	Properti yang Dijamin
Pesan dibaca orang lain	Password saja	**Enkripsi (AES, RSA…)**	Confidentiality
Data diubah di perjalanan	Enkripsi saja	**MAC/Digital Signature**	Integrity
Server/Identitas palsu	Hash biasa	**Auth Protocol/TLS**	Authentication

Pilih alat berdasarkan masalah, bukan berdasarkan popularitas atau kerumitan algoritma!

Bedah Kasus — Temukan Celahnya!

Analisis skenario sistem nyata:



Man-in-the-Middle Attack

Langkah #1 mengirim password plaintext. Penyerang mencegat sebelum enkripsi terjadi di server!

Solusi: Enkripsi di sisi client SEBELUM dikirim, atau gunakan HTTPS/TLS. Jangan percaya plaintext di jaringan!

Diskusi: Adakah celah lain dalam skenario ini? (Hint: Siapa yang punya kunci AES?)

💡 Pelajaran Penting

Inti dari semua yang kita pelajari hari ini:

❌ **Kriptografi bukan tentang algoritma paling kuat.**

✅ **Kriptografi adalah tentang memilih alat yang tepat untuk tujuan yang tepat.**



Pilih alat yang sesuai dengan pekerjaannya!

🔑 **Analogi Perkakas**

Kita tidak memakai palu godam untuk memperbaiki jam tangan.
Pilih alat yang tepat untuk tujuan yang tepat!

🏗️ Framework Berpikir Security Engineer

Urutan berpikir yang benar, selalu dimulai dari sini:

1	**Tentukan Aset**	Apa yang kita lindungi? Data apa yang berharga?
2	**Tentukan Ancaman**	Siapa musuh kita? Passive, Active, atau Insider?
3	**Tentukan Properti**	Confidentiality? Integrity? Auth? Non-Repudiation?
4	**Baru Pilih Algoritma**	Baru sekarang bicara teknis: AES, RSA, HMAC, dll.

Jangan lewatkan langkah!
Algoritma terbaik pun sia-sia jika kamu tidak tahu apa yang dilindungi dan dari siapa.

📌 Kesimpulan Hari Ini

Yang harus kita bawa pulang dari kelas ini:

1. Kriptografi bukan soal algoritma paling kuat, tapi soal memilih alat yang tepat untuk tujuan yang tepat.

2. Ada 4 properti keamanan: Confidentiality, Integrity, Authentication, Non-Repudiation.

3. Keamanan bersifat relatif. Sistem aman = aman terhadap penyerang tertentu dalam asumsi tertentu.

4. Urutan berpikir yang benar: Aset → Ancaman → Properti → baru Algoritma.

Pertanyaan utama kita bukan lagi "Pakai algoritma apa?", tapi "Kita ingin menjamin apa?"

PR MINGGU INI

Analisis Keamanan Aplikasi

Pilih SATU aplikasi: Gojek · Tokopedia · Discord · Steam · WhatsApp · Mobile Banking · Netflix · atau app lainnya

A

Identifikasi Aset

Data apa saja yang disimpan dan diproses aplikasi?
Contoh: data profil, history transaksi, lokasi real-time, pesan pribadi, dll.

B

Analisis Ancaman

Siapa yang bisa menjadi penyerang? Apa yang mereka inginkan?
Contoh: hacker eksternal, orang dalam perusahaan, pengguna iseng, kompetitor.

C

Tentukan Properti Keamanan

Properti mana yang paling kritis? Beri alasan!
Contoh: 'Perlu Confidentiality karena chat bersifat pribadi dan rahasia.'

SYARAT WAJIB:
Dilarang menyebut nama algoritma teknis! (AES, RSA, SHA, bcrypt, dll.)
Fokus pada KONSEP!

📋 FORMAT & CONTOH

Contoh Pengerjaan PR. Aplikasi: Gojek

Komponen	Contoh Isi Jawaban
Aset yang Dilindungi	Lokasi GPS pengguna, data pembayaran (kartu kredit/GoPay), riwayat perjalanan, data identitas driver, rating & review.
Potensi Ancaman	Hacker ingin mencuri data kartu kredit (active). Pengguna iseng memata-matai lokasi orang lain (passive). Karyawan internal yang bocorkan data driver (insider).
Properti Wajib	Confidentiality (lokasi & data pembayaran pribadi), Integrity (riwayat transaksi tidak boleh diubah), Authentication (pastikan yang login adalah pemilik akun).

Format bebas: bisa tabel, paragraf, atau poin-poin. Dikumpulkan minggu depan sebelum kelas dimulai.

✅ RUBRIK NILAI

Kriteria Penilaian PR

30 pts	**Identifikasi Aset** Lengkap dan relevan dengan aplikasi yang dipilih. Tidak hanya menyebut 'data pengguna' secara umum.
30 pts	**Analisis Ancaman** Menyebutkan minimal 2 tipe ancaman (passive/active/insider) dengan skenario yang masuk akal.
30 pts	**Properti Keamanan** Memilih properti yang tepat dan memberikan alasan yang kuat mengapa properti itu paling kritis.
10 pts	**Tidak Menyebut Algoritma** Bonus poin jika sama sekali tidak menyebut nama algoritma teknis. Full deduction jika menyebut AES/RSA/dll.

Total = 100 pts · Dikumpulkan: Minggu depan, sebelum kelas · Format file: docx/pdf)

Pesan Akhir

Kita tidak lagi bertanya:

"Pakai algoritma apa?"

Tapi kita bertanya:

"Kita ingin menjamin apa?"



- Confidentiality
- Integrity
- Authentication
- Non-Repudiation